

Compliance and Internal Audit

Source: <https://www.prarulebook.co.uk/prarules/compliance-and-internal-audit/03-03-2026>

Effective Date: 03-03-2026

Type: PRA Rule

Scraped: 2026-03-02 20:49

1

Application and Definitions

1.1

Unless otherwise stated, this Part applies to a CRR firm

1. (1) with respect to the carrying on of the following from an establishment in the UK :

1. (a) regulated activities ;
 2. (b) activities that constitute dealing in investments as principal , disregarding the exclusion in article 15 of Regulated Activities Order ;
 3. (c) ancillary activities ;
 4. (d) in relation to MiFID business , ancillary services ; and
 5. (e) unregulated activities in a prudential context ;
2. (2) [deleted.]
3. (3) in a prudential context with respect to activities wherever they are carried on; and
4. (4) taking into account any activity of other members of a group of which the firm is a member.

1.1A

2.1 to 2.2B do not apply to a firm with respect to the carrying on of benchmarking activities except to the extent that before IP completion day , they were made for the purpose of transposing an EU instrument.

1.2

In this Part, the following definitions shall apply: [Note: There are currently no Part specific definitions]

2

Compliance

2.1

A firm must establish, implement and maintain adequate policies and procedures sufficient to ensure compliance of the firm including its managers, employees and appointed representatives (or where applicable, tied agents) with its obligations under the regulatory system and for countering the risk that the firm might be used to further financial crime.

[Note: Art. 16(2) of MiFID II]

2.1A

A firm must, taking into account the nature, scale and complexity of its business, and the nature and range of relevant services and activities undertaken in the course of that business:

1. (1) establish, implement and maintain adequate policies and procedures designed to detect any risk of failure by the firm to comply with its obligations under the regulatory system, as well as the associated risks; and
2. (2) put in place adequate measures and procedures designed to minimise the risks detected as a result of compliance with 2.1A(1) and to enable the PRA to exercise their powers effectively under the regulatory system.

2.1B

A firm must establish and maintain a permanent and effective compliance function which operates independently, and which is responsible for:

1. (1) monitoring on a permanent basis, and assessing on a regular basis, the adequacy and effectiveness of the measures, policies and procedures put in place in accordance with 2.1A, and the actions taken to address any deficiencies in the firm's compliance with its obligations;
2. (2) advising and assisting the relevant persons responsible for carrying out relevant services and activities to comply with the firm's obligations under the regulatory system; and
3. (3) reporting to the management body, on at least an annual basis, on the implementation and effectiveness of the overall control environment for relevant services and activities, on the risks that have been identified as well as remedies undertaken or to be undertaken.

2.1C

A firm must ensure that:

1. (1) the compliance function is responsible for conducting an assessment on the basis of which it establishes a risk-based monitoring programme for the firm that takes into consideration all areas of the firm's relevant services and activities; and
2. (2) its compliance risk is comprehensively monitored by the compliance function, for which purposes the compliance function establishes a monitoring programme and priorities determined according to the compliance risk assessment referred to at 2.1C(1).

2.1D

In order to enable the compliance function to discharge its responsibilities properly and independently, a firm must ensure that:

1. (1) the compliance function has the necessary authority, resources, expertise and access to all relevant information;
2. (2) a compliance officer is appointed by the management body and that compliance officer is responsible for the compliance function and for any compliance reporting required in relation to its obligations under the regulatory system and General Organisational Requirements 4.7;
3. (3) the compliance function reports directly to the management body on an ad-hoc basis where it detects a significant risk of failure by the firm to comply with its obligations under the regulatory system;
4. (4) the relevant persons involved in the compliance function are not involved in the performance of the services or activities which they monitor; and
5. (5) the method of determining the remuneration of the relevant persons involved in the compliance function does not compromise their objectivity and is not likely to do so.

2.1E

1. (1) A firm need not comply with the requirements in 2.1D(4) or (5) where:

1. (a) in view of the nature, scale and complexity of its business, and the nature and range of the relevant services and

activities, compliance with the requirements under 2.1D(4) or (5) is not proportionate; and

2. (b) the firm's compliance function is, and continues to be, effective.

2. (2) Where a firm is relying on 2.1E(1), it must:

1. (a) be able to demonstrate to the PRA upon request that its compliance function continues to be effective; and

2. (b) assess on a regular basis whether the effectiveness of the compliance function has been, or is being, compromised by the reliance on 2.1E(1).

2.2

[Deleted]

2.2A

[Deleted]

2.2B

[Deleted]

2.3

[Deleted.]

2.4

[Deleted.]

2.5

[Deleted.]

2.6

1. (1) [Deleted.]

2. (2) [Deleted.]

3

Internal Audit

3.1

[Deleted]

3.1A

[Deleted]

3.2

[Deleted]

3.3

A firm must, where appropriate and proportionate in view of the nature, scale and complexity of its business and the

nature and range of relevant services and activities undertaken in the course of its business, establish and maintain an internal audit function which is separate and independent from the other functions and activities of the firm.

3.4

A firm must ensure that its internal audit function is responsible for:

1. (1) establishing, implementing and maintaining an audit plan to examine and evaluate the adequacy and effectiveness of the firm's systems, internal control mechanisms and arrangements;
2. (2) issuing recommendations based on the result of work carried out in accordance with that audit plan and verify compliance with those recommendations; and
3. (3) reporting in relation to internal audit matters in accordance with General Organisational Requirements 4.7.